



IDATA CHILE · INFORME DE DIAGNÓSTICO

Análisis de seguridad — defensoresnorte.cl

Diagnóstico de prospección · modo pasivo

Versión	1.0
Fecha	27-07-2026
Emitido por	IDATA Chile
Contacto	https://idatachile.com

Copia interna. Este PDF conserva las notas internas de IDATA. No lo entregue al cliente: genere la versión limpia sin `--con-notas-internas`.

Objetivo: <https://www.defensoresnorte.cl/> **Fecha del escaneo:** 2026-07-27 03:05 UTC **Modo:** pasivo (prospección, sin autorización — Ley 21.459 respetada) **Herramienta:** IDATA Sentinel, módulos `vuln`, `assets`, `privacy` **Verificación:** todos los hallazgos fueron contrastados manualmente contra el objetivo, DNS-over-HTTPS, Certificate Transparency y el repositorio oficial de WordPress.

1. Veredicto

La postura de seguridad del sitio es **deficiente**, pero el riesgo real no está donde suele mirarse. No son las cabeceras HTTP: está en **un panel de administración expuesto a Internet, un entorno de pruebas olvidado y un formulario de contacto que recoge datos sensibles sin una sola línea de información al titular.**

El sitio tiene también dos puntos sólidos que conviene reconocer: TLS 1.3 correctamente configurado y el núcleo de WordPress al día en su última versión.

Perfil de riesgo del cliente: es un estudio de abogados penalistas. Los datos que entra un visitante por el formulario de contacto son, casi por definición, datos sensibles bajo la Ley 21.719 (información relativa a la comisión de infracciones penales). Eso eleva el estándar exigible muy por encima del de un sitio corporativo común.

Nota interna — calidad del escaneo automatizado. Sentinel entregó 12/100 (F). Esa nota no es defendible ante el cliente tal como salió, por dos razones opuestas:

- **Sobrepenaliza** dos hallazgos que son falsos positivos (SPF y DMARC ausentes: ambos existen).
- **Subvalora gravemente la exposición real:** reportó "1 activo" cuando hay 9 hosts accesibles, incluido un WordPress de pruebas y el panel cPanel. El descubrimiento de subdominios falló y el resto del informe se construyó sobre ese inventario vacío.

El detalle está en las secciones 6 y 7, ambas internas.

2. Superficie de ataque

Inventario reconstruido desde los registros públicos de Certificate Transparency y verificado por resolución DNS y consulta HTTP a cada host:

HOST	DNS	RESPUESTA	QUÉ ES	RIESGO
www.defensoresnorte.cl	162.240.102.107	200	Sitio productivo, WordPress 7.0.2	—
defensoresnorte.cl	162.240.102.107	301 → www	Apex	—
beta.defensoresnorte.cl	162.240.102.107	500, WordPress 7.0.2	Entorno de pruebas expuesto	Alto
cpanel.defensoresnorte.cl	162.240.102.107	200 — cPanel Login	Panel de administración del hosting	Alto
webmail.defensoresnorte.cl	162.240.102.107	200 — Webmail Login	Acceso a correo	Medio
webdisk.defensoresnorte.cl	162.240.102.107	401 (cPanel)	WebDAV	Medio
cpcalendar.defensoresnorte.cl	162.240.102.107	401 (cPanel)	CalDAV	Bajo
cpcontacts.defensoresnorte.cl	162.240.102.107	401 (cPanel)	CardDAV	Bajo
autodiscover.defensoresnorte.cl	162.240.102.107	400	Autodiscover	Bajo
mail.defensoresnorte.cl	162.240.102.107	301 → www	Alias	—
aurora.defensoresnorte.cl	no resuelve	—	Certificado histórico	Informativo
racconto.defensoresnorte.cl	no resuelve	—	Certificado histórico	Informativo

Todo en una sola IP, sin CDN ni WAF por delante. No hay separación entre el sitio público, el entorno de pruebas y los paneles de administración: un compromiso de cualquiera de ellos es un compromiso del hosting completo.

Sentinel reportó Superficie: 1 activo(s), 1 accesible(s), 1 IP(s) . El inventario de arriba salió de reconstruirlo a mano. Ver sección 7.1.

3. Hallazgos principales

Ninguno de los siete hallazgos de esta sección fue detectado por el escaneo automatizado. Salieron de la verificación manual. Son, a la vez, los de mayor severidad del informe.

3.1 — CRÍTICO · Enumeración de usuarios por la API REST de WordPress

GET /wp-json/wp/v2/users responde 200 y entrega la lista completa de cuentas, **incluido el slug**, que es el nombre de usuario de acceso:

ID	NOMBRE	USUARIO DE LOGIN
1	Soporte Defensores Norte	_adm_defn0r_0520
2	Carlo Silva	a-dir_csilva
3	Cecilia Álvarez	a-jef_calvarez
4	srtv	srtv

El detalle que lo agrava: **alguien se tomó el trabajo de ofuscar el usuario administrador** (_adm_defn0r_0520 en vez de admin). Esa medida de seguridad es correcta y la API REST la anula por completo. El endpoint está anunciado por el propio servidor en la cabecera Link de cada respuesta.

Con el usuario administrador conocido y sin WAF ni CDN delante, el ataque de fuerza bruta o credential stuffing contra wp-login.php , XML-RPC y cpanel.defensoresnorte.cl deja de ser especulativo: solo falta la contraseña.

Corrección: restringir wp-json/wp/v2/users a usuarios autenticados, desactivar la enumeración por ?author=N y por /author/<slug>/ , y forzar 2FA en WordPress y cPanel.

3.2 — ALTO · Entorno de pruebas beta. expuesto a Internet

beta.defensoresnorte.cl es una **segunda instalación de WordPress 7.0.2** que devuelve HTTP 500 pero sigue viva: su API REST responde 200 y expone **las mismas cuentas de usuario, con biografías completas**. No filtra rutas del sistema ni trazas de error (verificado), pero eso es lo único bueno.

Un entorno beta es el eslabón débil clásico: se parchea tarde, nadie mira sus logs, suele tener credenciales reales y comparte servidor con producción. Que además esté devolviendo 500 sugiere que está abandonado, no en uso.

Corrección: sacarlo de Internet. Si se necesita, ponerlo tras autenticación HTTP básica o restricción por IP, con X-Robots-Tag: noindex y credenciales distintas de producción.

3.3 — ALTO · Formulario de contacto sin información al titular (Ley 21.719)

El formulario del sitio está en /contacto/ — Contact Form 7 — y recoge:

CAMPO	DATO
<code>your-name</code>	Nombre
<code>your-elecmail</code>	Correo electrónico
<code>your-phone</code>	Teléfono
<code>your-subject</code>	Asunto
<code>textarea</code>	Mensaje libre

En la página **no aparece ninguna mención a privacidad, tratamiento de datos, la Ley 21.719, consentimiento ni términos** (verificado por búsqueda de texto). No hay casilla de consentimiento ni enlace a política alguna.

Para un estudio penalista, el campo de mensaje libre recibirá relatos de imputaciones, detenciones y causas en curso. Eso es **dato sensible** con estándar reforzado: exige base de licitud explícita, información previa al titular y medidas de seguridad acreditables. Recoger eso sin una línea de información es la brecha más costosa del sitio.

3.4 — MEDIO · Transferencias internacionales de datos

El sitio carga **tres servicios de Google en cada visita**, todos antes de cualquier consentimiento:

SERVICIO	RECURSO	QUÉ TRANSFIERE
Google Analytics / Site Kit	<code>googletagmanager.com/gtag/js?id=GT-57Z7FDQ</code>	Identificador, navegación, IP
Google Fonts	<code>fonts.googleapis.com</code> , <code>fonts.gstatic.com</code>	IP + User-Agent en cada carga
reCAPTCHA v3	<code>www.google.com/recaptcha/api.js</code>	Perfilado continuo de comportamiento en toda página donde carga

Los dos últimos son invisibles para Sentinel porque no están en `data/trackers.yaml` .

reCAPTCHA v3 es el más delicado de los tres: no es un desafío puntual, evalúa al usuario de forma continua. Google Fonts es el caso que motivó sanciones en la UE precisamente por transferir la IP sin base legal, y se resuelve simplemente **autoalojando las fuentes**.

3.5 — MEDIO · Correo: los registros existen, pero no aplican nada

El dominio publica SPF, DMARC y DKIM. El problema no es su ausencia, es que ninguno está configurado para bloquear nada:

```
defensoresnorte.cl  TXT      v=spf1 ip4:162.240.102.107 ip4:162.214.192.209 +a +mx
                        +include:_spf.google.com ~all
_dmarc.defensoresnorte.cl  TXT      v=DMARC1; p=none; rua=mailto:dmarc-repor-
ts@defensoresnorte.cl
```

- **p=none** — DMARC está publicado pero **no aplica nada**. Un correo que suplanta al dominio y falla la validación se entrega igual. Solo genera reportes.
- **~all** (softfail) en vez de **-all** — el receptor no está instruido para rechazar.
- **+a +mx** autoriza a enviar correo al servidor web y a todos los MX. Es una ampliación innecesaria: si el servidor web se compromete, puede enviar correo firmado como el estudio.
- **DKIM google._domainkey usa clave RSA de 1024 bits** — por debajo del estándar actual de 2048.

Para un estudio de abogados, suplantar su dominio para escribirle a un cliente es un vector de fraude directo y muy rentable. Hoy nada lo impide técnicamente.

Corrección: subir a **p=quarantine** y luego **p=reject** tras revisar los reportes **rua** ; cambiar **~all** por **-all** ; quitar **+a +mx** ; rotar la clave DKIM a 2048 bits.

3.6 — MEDIO · Ocho componentes de WordPress desactualizados

El núcleo está al día (WordPress 7.0.2 **es la última versión** — confirmado contra **api.wordpress.org**). Ese es el punto fuerte del sitio y conviene decirlo. Pero los plugins, que es donde aparecen la mayoría de los CVE de WordPress, no lo están:

COMPONENTE	INSTALADA	ÚLTIMA	ESTADO
Elementor	4.0.9	4.2.0	Desactualizado
Elementor Pro	4.0.4	— (premium)	Sin verificar
ElementsKit Lite	3.9.6	3.10.02	Desactualizado
Header Footer Elementor	2.8.7	2.9.2	Desactualizado
Jeg Elementor Kit	3.2.0	3.2.10	Desactualizado
WP WhatsApp Chat	8.5.0	8.6.1	Desactualizado
Sticky Header Effects	2.1.8	2.2.0	Desactualizado
Metronet Profile Picture	2.6.3	2.6.4	Desactualizado
Contact Form 7	6.1.6	6.1.6	Al día
Tema cream-blog	2.1.7	2.1.7	Al día
Popup Maker	indeterminada	1.23.0	Sin verificar

Cada versión exacta es pública porque va en el parámetro `?ver=` de cada CSS y JS. Con la versión y el plugin identificados, buscar exploits publicados es trabajo de minutos y no requiere tocar el servidor.

3.7 — BAJO · Redirección HTTP→HTTPS con 302

`http://www.defensoresnorte.cl/` responde **302** (temporal) en vez de 301 (permanente). Combinado con la ausencia de HSTS, ningún navegador memoriza que el sitio debe ser HTTPS: cada primera visita sigue viajando en claro y es interceptable.

3.8 — Cabeceras de seguridad ausentes

Confirmadas como faltantes en `/`: HSTS, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Cross-Origin-Opener-Policy, Cross-Origin-Resource-Policy y Permissions-Policy. También falta `/.well-known/security.txt`, y la versión de WordPress se publica en la meta `generator`.

Son higiene necesaria, pero de impacto menor comparadas con los puntos 3.1 a 3.3. TLS está bien configurado (TLSv1.3, cadena confiable, certificado vigente).

4. Plan de remediación priorizado

#	ACCIÓN	IMPACTO	ESFUERZO	PLAZO
1	Cerrar <code>beta.defensoresnorte.cl</code> o ponerlo tras autenticación	Alto	Bajo	Inmediato
2	Bloquear enumeración de usuarios (<code>wp-json/wp/v2/users</code> , <code>?author=</code> , <code>/author/</code>)	Alto	Bajo	Inmediato
3	Activar 2FA en WordPress y cPanel; limitar intentos de acceso	Alto	Bajo	Inmediato
4	Publicar política de privacidad y enlazarla desde el pie; aviso + consentimiento en <code>/contacto/</code>	Alto (legal)	Medio	1 semana
5	DMARC a <code>p=quarantine</code> , SPF a <code>-all</code> , quitar <code>+a +mx</code> , DKIM a 2048 bits	Alto	Bajo	1 semana
6	CMP que bloquee Analytics y reCAPTCHA antes del consentimiento; autoalojar Google Fonts	Alto (legal)	Medio	2 semanas
7	Actualizar los 8 plugins desactualizados; activar actualizaciones automáticas	Medio	Bajo	2 semanas
8	Restringir <code>cpanel / webmail / webdisk</code> por IP o VPN	Medio	Medio	2 semanas
9	Cabeceras: HSTS, CSP, X-Frame-Options, nosniff, Referrer-Policy, COOP	Medio	Bajo	1 mes
10	301 en vez de 302 para HTTP→HTTPS	Bajo	Bajo	1 mes
11	CAA, DNSSEC, MTA-STS, TLS-RPT	Bajo	Medio	1 mes
12	Ocultar versión de WordPress y de plugins (<code>?ver=</code>)	Bajo	Bajo	1 mes
13	Publicar <code>/.well-known/security.txt</code>	Bajo	Bajo	Cuando se pueda
14	Evaluar CDN/WAF delante del origen	Medio	Medio	Trimestre

Los puntos 1-3 son los que cambian el perfil de riesgo de verdad. El resto es higiene necesaria pero no urgente.

5. Alcance y límites de este análisis

- **Escaneo pasivo.** Solo se leyó información que el servidor publica por sí mismo: HTML, cabeceras, DNS, registros de Certificate Transparency y endpoints anunciados por el propio servidor en su cabecera `Link` . No hubo fuerza bruta, prueba de credenciales, inyección, fuzzing de rutas ni explotación de vulnerabilidad alguna.

- **No se verificó la explotabilidad** de ningún hallazgo. "Plugin desactualizado" significa que existe una versión más nueva, no que exista un exploit funcional contra este sitio.
- **Falta lo que solo un modo auditoría autorizado puede ver:** `xmlrpc.php` , `wp-login.php` , archivos de respaldo, `readme.html` , listado de directorios, configuración de cookies tras interacción, y el comportamiento real del formulario al enviarse.
- **El semáforo 21.719 son señales técnicas observables**, no una calificación legal. Corresponde al servicio de Datos Personales de IDATA emitir el juicio de cumplimiento.
- **Los certificados históricos** (`aurora.` , `racconto.`) no resuelven hoy. Sin CNAME colgante, no hay riesgo de takeover; quedan como constancia de activos retirados.

6. Falsos positivos del escaneo automatizado

HALLAZGO DE SENTINEL	REALIDAD	CAUSA
<code>spf_missing@www.defensoresnorte.cl</code> evidencia: "TXT observados: (ninguno)"	SPF existe en el apex y se resuelve también para <code>www</code> por CNAME	La consulta TXT falló por timeout del resolver y el check trató el fallo como ausencia
<code>dmARC_missing@www.defensoresnorte.cl</code> recomienda "publicar <code>_dmarc.www...</code> "	DMARC existe en <code>_dmarc.defensoresnorte.cl</code>	El check consulta <code>_dmarc.<host></code> en vez del dominio organizacional. La recomendación además es incorrecta : publicar DMARC en <code>www</code> . no es la práctica correcta

Estos dos suman 11,2 puntos de penalización indebida. La recomendación de DMARC es lo más serio: entregada tal cual, el cliente publicaría un registro en el lugar equivocado y creería estar protegido.

Confirmados como correctos (verificados uno a uno): ausencia de CAA, ausencia de DNSSEC, ausencia de MTA-STS y TLS-RPT, todas las cabeceras faltantes, TLS 1.3 sano, ausencia de política de privacidad enlazada, y la exposición de versión de WordPress.

7. Crítica al instrumento — qué corregir en IDATA Sentinel

Cuatro defectos, en orden de impacto sobre la credibilidad del informe.

7.1 — El descubrimiento de subdominios está roto para todos los objetivos

Dos bugs encadenados en `checks/subdomains.py` :

a) Se consulta el host, no el dominio registrable. `modules/asset_inventory/module.py:59` pasa `ctx.host` , que aquí es `www.defensoresnorte.cl` . La consulta que sale es `%www.defensoresnorte.cl` — nunca habrá certificados bajo ese nombre. Con `www.` en la URL, el inventario siempre da vacío.

b) La forma de consulta devuelve 404. checks/subdomains.py:14 construye

`https://crt.sh/?q=%25.{domain}&output=json` . Verificado hoy:

```
404  https://crt.sh/?q=%25.defensoresnorte.cl&output=json
200  https://crt.sh/?q=www.defensoresnorte.cl&output=json  (22.877 bytes)
200  https://crt.sh/?q=defensoresnorte.cl&output=json      (88.721 bytes, 17 nombres)
```

crt.sh ya no acepta la forma comodín en esa ruta. La consulta sin `%` devuelve el árbol completo del dominio.

Arreglo: derivar el dominio registrable (quitar `www.` y subdominios) antes de consultar, usar `?q=<dominio>&output=json` , y añadir reintento con espera ante 502/timeout — crt.sh es intermitente por naturaleza (en las pruebas alternó 200, 404, 502 y timeout).

El mérito de la herramienta aquí es que **avisó** de que el inventario estaba incompleto (`asset_discovery_incomplete`) en vez de presentar "1 activo" como verdad. Ese diseño es correcto y salvó el informe. Pero es un aviso que hoy se dispara siempre.

7.2 — El score global no es un promedio: es una suma de penalizaciones

`scoring/risk_engine.py:74` calcula el score global sobre todos los hallazgos juntos, mientras que cada módulo se calcula sobre los suyos:

```
vuln      100 - 32,6 = 67
assets    100 - 17,8 = 82
privacy   100 - 38,0 = 62
global    100 - 88,4 = 12  ← suma de las tres, no promedio
```

Consecuencias prácticas:

- **El score depende de cuántos módulos se corran.** El mismo sitio con `--modules vuln` saca 67; con los tres, 12. Dos escaneos no son comparables entre sí, y el histórico de monitoreo tampoco si cambia el conjunto de módulos.
- **La nota satura.** Con 88 puntos de penalización, la escala ya no discrimina: un sitio con problemas moderados y uno realmente comprometido caen ambos en F. Se pierde exactamente la información que el cliente necesita para priorizar.
- **Doble conteo.** `hsts_missing` penaliza en `vuln` y otra vez, vía el semáforo 21.719, en `privacy` .

Arreglo: el score global como media ponderada de los módulos ejecutados, con pesos declarados. Y dejar constancia en el reporte de qué módulos entraron en la nota.

7.3 — Un fallo de red se reporta como ausencia

El README establece el principio correcto: "un fallo de red produce un resultado 'no evaluable' que no penaliza el score, para no confundir 'no pude medirlo' con 'está mal'". Los checks de DNS no lo cumplen. La consulta TXT dio timeout y el resultado fue `spf_missing` con

severidad media y evidencia "TXT observados: (ninguno)" — que se lee como una observación positiva de ausencia.

Arreglo: en los checks de DNS, distinguir NXDOMAIN / NoAnswer (ausencia real) de Timeout / SERVFAIL (no evaluable), igual que ya se hace con HTTP. Reintentar con un resolver alternativo antes de concluir.

7.4 — Cobertura: solo se mira / , y faltan terceros en el catálogo

- **El módulo `privacy` analiza únicamente la raíz.** En este sitio eso significó no ver el único formulario que existe. Es el patrón habitual: la home es comercial, los datos se recogen en `/contacto/` . Propuesta: seguir los enlaces de la navegación y del pie (2-3 páginas, con el rate limit ya existente), o al menos leer `wp-sitemap.xml` / `robots.txt` — que aquí publica el sitemap completo — y priorizar URLs que contengan contacto, cotiza, suscri, registro.
- **`data/trackers.yaml` no incluye Google Fonts, `fonts.gstatic.com` ni reCAPTCHA.** Son tres de los terceros más frecuentes en sitios chilenos y los tres transfieren datos a Google LLC. Añadirlos es una línea cada uno y sube mucho la calidad del módulo estrella.
- **`data/cve_hints.yaml` no cubre plugins de WordPress.** El fingerprint detecta "WordPress 7.0.2" pero ignora los once plugins cuya versión el propio HTML publica en `?ver=` . En WordPress, el riesgo vive en los plugins, no en el núcleo. Extraer `plugins/<slug>/...?ver=<x>` del HTML y contrastar contra `api.wordpress.org` es barato y sin coste para el objetivo — y es lo que produjo el hallazgo 3.6 de este informe.
- **No hay check de enumeración de usuarios de WordPress**, pese a que el endpoint lo anuncia el servidor en su propia cabecera `Link` . Es el hallazgo de mayor valor de todo este análisis y hoy la herramienta no lo ve.

Escaneo generado con IDATA Sentinel (modo pasivo) y verificación manual sobre su resultado. Los datos crudos del escaneo están en `out/defensoresnorte.json` .